

Методичка по статье

«Исследование методов взаимодействия автономных агентов кибербезопасности на основе протоколов обмена контекстом»

Этот конспект объясняет статью с нуля: о чём она, какие термины надо знать, что и зачем сделано в каждом разделе, и какие вопросы можно ожидать на защите. Читать сверху вниз.

1. О чём вообще речь, в одном абзаце

Современный центр мониторинга кибербезопасности (SOC) — это не один продукт, а конструктор из десятков подсистем: сборщиков логов, антивирусов на конечных устройствах, сетевых сенсоров, баз данных об угрозах, систем автоматического реагирования. Эти подсистемы написаны разными вендорами и говорят на разных «языках». Чтобы они могли согласованно работать как команда автономных агентов, нужны **протоколы обмена контекстом** — стандартные форматы, на которых компоненты передают друг другу факты о происходящем («вот подозрительное событие», «вот связанный с ним индикатор», «вот команда заблокировать хост»). Статья отвечает на вопрос: **достаточно ли существующих протоколов, чтобы построить полностью автономную мультиагентную защиту, и если нет — какой архитектурный слой нужно добавить.**

Ответ статьи: ни одного протокола в отдельности не хватает, нужен промежуточный **брокер контекста** + три количественные метрики качества обмена (КПК, ЗРК, КССА).

2. Теоретическая база (нужный минимум с нуля)

2.1 Что такое SOC, SIEM, EDR, NDR, SOAR

- **SOC** (Security Operations Center) — команда + инструменты, которые круглосуточно следят за событиями безопасности в инфраструктуре компании. Аналитик SOC — это человек, который смотрит на алерты и решает, что делать.
- **SIEM** (Security Information and Event Management) — большая база данных + поисковик по логам. Туда стекаются журналы со всех серверов, антивирусов, сетевого оборудования. SIEM пишет правила корреляции: «если за 1 минуту 100 неудачных логинов с одного IP — алерт».
- **EDR** (Endpoint Detection and Response) — агент на рабочей станции/сервере. Следит, какие процессы запускаются, какие файлы открываются, какие сетевые соединения уходят, и отправляет это в SIEM.
- **NDR** (Network Detection and Response) — то же, но в сетевом трафике: DPI, NetFlow, обнаружение C2-каналов.

- **SOAR** (Security Orchestration, Automation and Response) — автоматизатор. Принимает алерт от SIEM и по заранее написанному **плейбуку** (последовательность шагов) сам блокирует пользователя, изолирует машину, открывает тикет и т.д.

Аналогия: SIEM — мозг (анализирует), EDR/NDR — глаза/уши (собирают данные), SOAR — руки (выполняет действия).

2.2 Что такое CTI и Threat Intelligence

- **Threat Intelligence (CTI)** — структурированные знания об угрозах: индикаторы компрометации (IP-адреса C2-серверов, хеши вредоносного ПО), описания группировок, тактики и техники атак.
- **IOC** (Indicator of Compromise) — атомарный признак заражения: IP, домен, хеш файла, ключ реестра.
- **TTP** (Tactics, Techniques, Procedures) — более высокоуровневое описание: «группировка APT-X сначала фишингом получает доступ, затем поднимает привилегии через CVE-XYZ, затем экспортирует данные через DNS».

2.3 Что такое MITRE ATT&CK

Открытая база знаний от MITRE Corporation, в которой все известные техники атак расклассифицированы:

- **Tactic** — общая цель злоумышленника (например, «Initial Access», «Persistence», «Exfiltration»).
- **Technique** — способ достижения цели («Phishing», «Valid Accounts»).
- **Sub-technique** — конкретная вариация («Spearphishing Attachment»).

Это **онтология** — общий язык, на котором аналитики со всего мира описывают одни и те же атаки одинаково. В статье ATT&CK используется как нормирующий словарь для семантического обогащения.

2.4 Что такое LLM и автономный агент

- **LLM** (Large Language Model) — большая языковая модель (GPT-4, Claude, Gemini). Умеет рассуждать над текстом, классифицировать, суммаризировать.
- **Автономный агент** в кибербезопасности — программа на базе LLM + набора инструментов. LLM решает «что сделать», инструменты исполняют («запрос в SIEM», «команда блокировки на МЭ»). Агент работает циклом: **наблюдай** → **планируй** → **действуй** → **наблюдай**.
- **Мультиагентная система** — несколько таких агентов работают параллельно, каждый отвечает за свою функцию (один обнаруживает, второй обогащает контекстом, третий реагирует), и общаются между собой.

2.5 Что такое контекст и почему он критичен

Контекст в статье — структурированная информация об одном событии безопасности: что произошло, когда, на каком хосте, какие связанные индикаторы, к какой тактике АТТ&СК относится, кто из агентов уже видел это событие. Если контекст потеряли при передаче — агент-получатель будет принимать решение «вслепую» (на неполных данных) и может выполнить деструктивное действие. Именно поэтому центральная тема статьи — **качество обмена контекстом**.

3. Шесть рассмотренных протоколов — кто за что отвечает

Все шесть стандартов проектировались разными организациями для разных задач. Поэтому они **не заменяют, а дополняют** друг друга — но никто не закрывает полный цикл.

3.1 STIX 2.1 / TAXII 2.1 — язык разведки угроз

- **STIX** — формат: как описать индикатор, актора, кампанию. Объекты называются SDO (STIX Domain Object), отношения — SRO.
- **TAXII** — транспорт: HTTPS-протокол публикации и подписки на коллекции STIX-объектов.
- Принят OASIS 10 июня 2021 г.
- **Пример STIX-индикатора:**

```
{
  "type": "indicator",
  "pattern": "[file:hashes.'SHA-256' = 'abc123...']",
  "labels": ["malicious-activity"]
}
```

- **Минусы для нашей задачи:** обмен принципиально асинхронный (часы, сутки), внутреннее состояние агента не передаётся.

3.2 OCSF — нормализация событий

- **OCSF** (Open Cybersecurity Schema Framework) — JSON-схема для первичных событий: 14 категорий (сетевая активность, файловые операции, аутентификация и т.д.). Создан AWS + Splunk в 2022 г., передан Linux Foundation 19 ноября 2024 г.
- Текущая версия — **v1.3** (август 2024).
- Идея: что бы ни прислал EDR/NDR/SIEM — приводим к одному виду через OCSF, и дальше все агенты понимают друг друга.
- **Минус:** OCSF описывает только структуру данных, но не транспорт. Нужен Kafka/gRPC отдельно.

3.3 CACAO 2.0 — плейбуки реагирования

- **CACAO** (Collaborative Automated Course of Action Operations) — формат для описания плейбуков SOAR в виде графа шагов с условиями переходов и обработкой ошибок.

- Committee Specification 01 от 27 ноября 2023 г. (OASIS).
- **Пример шага CACAO:**

Шаг 1: получить IP подозрительного хоста (из контекста STIX)
 Шаг 2: вызвать OpenC2-команду блокировки → межсетевой экран
 Шаг 3: если успех → лог в SIEM; если нет → алерт аналитику

- **Минус:** шаги статичны — нет места для рассуждения LLM на лету.

3.4 OpenC2 — атомарные команды защиты

- **OpenC2** определяет язык команд в виде тройки «**action — target — actuator**» («что сделать — над чем — кем»). Committee Specification 02, 24 ноября 2019 г.
- **Пример команды OpenC2:**

```
{"action": "deny", "target": {"ipv4_net": "10.0.0.5/32"},
  "actuator": {"network_firewall": {}}}
```

Что значит: «межсетевой экран, заблокируй IP 10.0.0.5».

- **Минус:** OpenC2 знает, **что** делать, но не знает, **почему** — нет привязки к разведывательному контексту.

3.5 MCP — подключение LLM к инструментам

- **MCP** (Model Context Protocol) — спецификация Anthropic от 25 ноября 2024 г. для подключения LLM-агентов к внешним системам через три примитива: **tools** (функции), **resources** (доступ к данным), **prompts** (шаблоны).
- Работает поверх **JSON-RPC 2.0**.
- В первой половине 2025 г. поддержан OpenAI (март), Google DeepMind (апрель), Microsoft (Build 2025) — стал де-факто стандартом.
- **Минус:** доменно-нейтральный, не знает терминологии ИБ. Не предназначен для координации **между** агентами — только клиент↔инструмент.

3.6 A2A — прямая связь между агентами

- **A2A** (Agent-to-Agent) — спецификация Google от 9 апреля 2025 г. для прямой координации агентов разных вендоров.
- Использует HTTP + Server-Sent Events (SSE) + JSON-RPC 2.0.
- Базовые сущности: **Agent Card** (паспорт агента), **Task** (задача), **Artifact** (результат).
- **Минус:** тоже доменно-нейтральный, не понимает «индикатор компрометации» как сущность.

3.7 Сводная картина

Уровень	Протокол	Что закрывает	Чего не хватает
---------	----------	---------------	-----------------

Уровень	Протокол	Что закрывает	Чего не хватает
Нормализация	OCSF	Структура события	Транспорт
Разведка	STIX/TAXII	IOC, TTP, акторы	Реальное время
Исполнение	OpenC2 + CACAO	Команды и плейбуки	Семантика угроз
Координация LLM	MCP, A2A	Связь агент↔инструмент, агент↔агент	Знание ИБ-онтологии

Ключевой вывод: между уровнями есть **семантические разрывы** — атрибуты OCSF не мапятся напрямую в STIX, OpenC2-команды не содержат «откуда взялось решение». Нужен слой-переводчик.

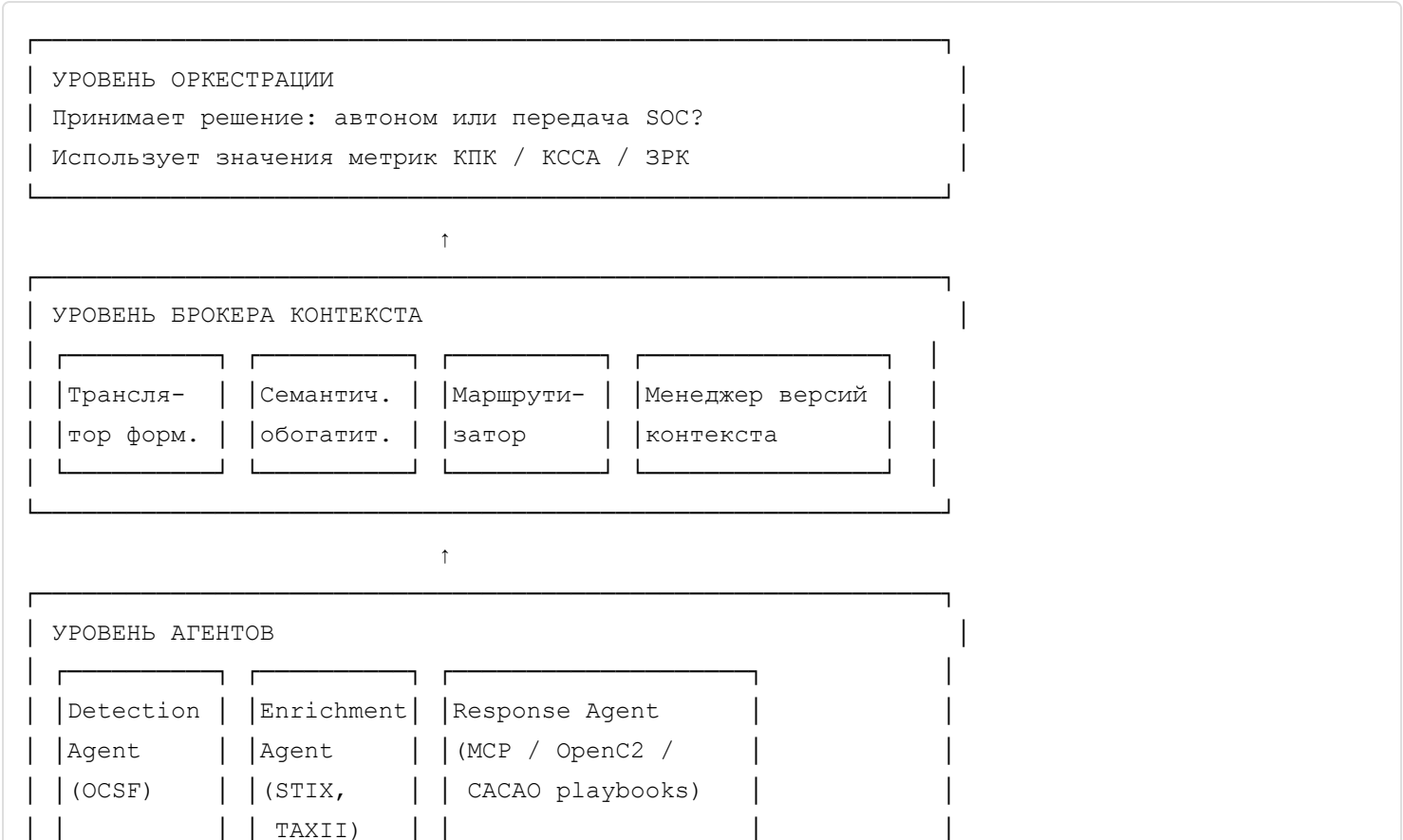
4. Что предлагает статья: брокер контекста

4.1 Идея

Поставить между агентами централизованный **брокер** — узел, через который проходит весь контекст. Брокер не делает работу агентов, он:

- 1. **транслирует** форматы (STIX ↔ OCSF ↔ MCP/A2A) по явным таблицам соответствия;
- 2. **обогащает** события привязкой к MITRE ATT&CK (добавляет Tactic/Technique/Sub-technique);
- 3. **маршрутизирует** сообщения по приоритету;
- 4. **версиониров** контекст — иммутабельный журнал для аудита.

4.2 Три уровня архитектуры



- **Detection Agent** — слушает EDR/NDR, нормализует в OCSF.
- **Enrichment Agent** — ходит в TAXII за объектами STIX (Indicator, Attack Pattern, Threat Actor, Campaign).
- **Response Agent** — исполняет MCP-инструменты и команды OpenC2 (блокировка, изоляция).
- **Уровень оркестрации** общается с агентами по A2A через Task/Artifact.

4.3 Сценарий работы (рис. 4.2 статьи)

1. Источник телеметрии → агенту обнаружения сырое событие (NetFlow / Sysmon).
2. Агент обнаружения → брокеру OCSF-объект.
3. Брокер видит, что контекста мало (низкий КПК) → запрос обогащения у Enrichment Agent через TAXII 2.1.
4. Enrichment Agent возвращает Indicator + Attack Pattern + Threat Actor.
5. Брокер считает КПК, привязывает к АТТ&СК, передаёт обогащённый контекст + Confidence Score агенту реагирования.
6. Агент реагирования проверяет пороги:
 - **6a.** КПК $\geq 0,7$ и КССА $\geq 0,85$ → исполняет САСАО-плейбук с OpenC2-командами автономно;
 - **6b.** иначе → формирует алерт + сводку контекста для аналитика SOC.

5. Три метрики качества обмена

Это сердцевина новизны статьи. Каждая метрика отвечает за свой аспект.

5.1 КПК — Коэффициент Полноты Контекста

Что измеряет: сколько обязательных и рекомендуемых атрибутов схемы OCSF заполнено в полученном объекте.

$$\text{КПК} = N_{\text{заполн}} / N_{\text{общ}}$$

- **Порог:** $\geq 0,7$. Ниже — агент не знает «достаточно», чтобы решать сам.
- **Зачем нужен:** автономное действие на неполных данных = риск ошибки.

5.2 ЗРК — Задержка Распространения Контекста

Что измеряет: время от регистрации события источником до получения обогащённого контекста агентом реагирования.

$$ЗРК = t_{получ} - t_{фикс}$$

- **Порог:** ≤ 500 мс. Иначе атакующий процесс уже завершит вредоносное действие к моменту реакции.
- **Зачем нужен:** требование SOAR-уровня real-time.

5.3 КССА — Коэффициент Семантической Согласованности Агентов

Что измеряет: долю сообщений, которые агент-получатель понял без запроса уточнения.

$$КССА = N_{без_уточн} / N_{общ_сообщ}$$

- **Порог:** $\geq 0,85$. Ниже — есть онтологическое расхождение (например, разные версии OCSF).
- **Зачем нужен:** если агенты «понимают друг друга по-разному», координация невозможна.

5.4 Условие автономности

Все три порога выполнены одновременно:

$$КПК \geq 0,7 \quad \wedge \quad ЗРК \leq 500 \text{ мс} \quad \wedge \quad КССА \geq 0,85$$

Если хотя бы один нарушен — режим переключается на полуавтоматический, аналитик SOC получает сводку и решает сам.

6. Конкретный пример «от атаки до реакции»

Чтобы метрики и архитектура стали ощутимыми — разбор одного сценария.

Сценарий: на рабочей станции Windows пользователь открыл вложение, которое запустило PowerShell с обращением к подозрительному домену.

Шаг	Кто	Что делает	Контекст	Метрика
1	EDR	Регистрирует событие создания процесса powershell.exe -enc <base64> , t=0 мс	Сырое Sysmon-событие	—
2	Detection Agent	Нормализует в OCSF (категория Process Activity), 28 из 40 атрибутов заполнено	OCSF Process Activity Event	КПК=0,70
3	Брокер	Получает событие в t=80 мс	+ временная метка	ЗРК пока 80 мс
4	Enrichment Agent	По TAXII запрашивает STIX-индикатор для домена. Получает Threat Actor «APT-X», Attack Pattern T1059.001	+ Indicator, Attack Pattern, Threat Actor	КПК растёт до 0,92
5	Брокер	Семантический обогатитель добавляет MITRE ATT&CK: Tactic=Execution, Technique=Command and Scripting Interpreter, Sub-technique=PowerShell	+ ATT&CK-разметка	—
6	Брокер	Передаёт Response Agent в t=380 мс с Confidence Score=0,88	Обогащённый OCSF + ATT&CK	ЗРК=380 мс

Шаг	Кто	Что делает	Контекст	Метрика
7	Response Agent	Проверка: КПК=0,92 ≥ 0,7 ✓ ; ЗРК=380 ≤ 500 ✓ ; КССА=0,91 ≥ 0,85 ✓ — автономный режим	—	Все пороги ✓
8	Response Agent	Исполняет CACAO-плейбук: OpenC2-команда (isolate, host, edr_agent) для рабочей станции; OpenC2-команда (deny, ipv4_net, network_firewall) для C2-IP	Артефакт A2A: список выполненных действий	—

Если бы Enrichment Agent не смог ответить (TI-платформа недоступна), КПК остался бы 0,70 — на границе порога, КССА мог просесть из-за неполных данных → брокер бы передал управление аналитику SOC с сводкой.

7. Поразделный разбор статьи

7.1 Аннотация и ключевые слова

Аннотация — это вход для рецензента и поисковика. Здесь концентрированно перечислено всё, что есть в работе: список протоколов, признаки сравнения, главные результаты (брокер + три метрики + пороги). Дублируется на английском, поскольку это требование к научным публикациям.

7.2 Введение

Структура — стандартная для научной статьи:

1. **Контекст эпохи** (переход от сигнатур к мультиагентным защитам, появление LLM и SOAR).
2. **Проблема** (несогласованный обмен порождает потерю атрибутов, рассинхронизацию состояний, невозможность аудита).
3. **Обзор поля** (перечень шести протоколов с указанием, какую часть они закрывают).
4. **Объект** (процессы обмена контекстом) и **предмет** (протоколы и методы согласования) — это терминология из ГОСТ Р 7.0.11 для научных работ.
5. **Актуальность** — почему задачу важно решать сейчас.
6. **Научная новизна** — что **впервые** делается в работе.
7. **Цель и задачи** — что планируем достичь и шагами как.
8. **Структура работы** — карта статьи для читателя.

7.3 Раздел 1. Обзор существующих подходов

Шесть подразделов:

- **1.1** — историческая база: Городецкий, Котенко (FIPA ACL в 2000-х), Браницкий и Котенко (2016 — систематизация методов обнаружения). Объясняется, почему ранние подходы не масштабируются.
- **1.2** — STIX/TAXII: что описывают, где применяются (OpenCTI, MISP).
- **1.3** — CACAO 2.0 и OpenC2: вместе образуют слой исполнения.

- **1.4** — OCSF: нормализация телеметрии.
- **1.5** — MCP и A2A: новейшие LLM-протоколы.
- Каждый подраздел заканчивается **ограничениями** протокола — это нужно, чтобы в разделе 2 свести их в общую картину.

Зачем такая структура: читатель сначала видит каждый стандарт изолированно (с его «правдой»), а потом понимает, что вместе они не закрывают цикл.

7.4 Раздел 2. Сравнительный анализ

Таблица 2.1 — главный артефакт раздела. По пяти признакам (модель взаимодействия, формат, применение в ИБ, ограничения, поддержка реального времени) шесть протоколов раскладываются как пасьянс.

Выводы из таблицы:

- Четыре функциональных уровня (нормализация / разведка / исполнение / координация LLM) — никто не покрывает все четыре.
- Семантические разрывы между уровнями.
- LLM-протоколы доменно-нейтральны.

Логика: «вот наглядное доказательство, что одного стандарта недостаточно — нужен связующий слой».

7.5 Раздел 3. Метрики

Здесь вводится количественная база. Структура раздела зеркальная — три подраздела, по одному на метрику, плюс четвёртый — условия совместного применения.

Каждый подраздел построен по схеме:

1. Что измеряет.
2. Формула.
3. Расшифровка переменных через «где...».
4. Порог и его обоснование.
5. Что делать, если порог не выполнен.

Почему именно три метрики: информация, время, семантика — три измерения качества коммуникации. Меньше — не покрывает картину; больше — избыточно.

7.6 Раздел 4. Архитектура

Самый объёмный раздел — практическое предложение. Четыре подраздела + рисунок 4.1 (структура) + рисунок 4.2 (сценарий).

- **4.1** — что делают агенты (три типа).
- **4.2** — что делает брокер (четыре модуля).

- **4.3** — что делает оркестратор (использует метрики для принятия решения).
- **4.4** — сценарий «событие → реакция» (рис. 4.2).

Принцип: разделение ответственности. Каждый слой делает одну вещь и делает её хорошо.

7.7 Раздел 5. Обсуждение результатов

Четыре подраздела:

- **5.1** — сравнение с типовыми коммерческими SOAR (что предложение даёт сверх того, что уже есть).
- **5.2** — научная новизна, аккуратно сформулированная (три аспекта).
- **5.3** — честные ограничения (зависимость от АТТ&СК, централизованная модель брокера, недетерминированность LLM).
- **5.4** — направления дальнейших работ (формализация онтологии, прототип, верификация порогов, защита от состязательных воздействий).

Зачем 5.3 обязателен: в научной публикации без раздела «ограничения» рецензенты подозревают, что автор не понимает границы применимости.

7.8 Заключение

Пятичастная структура (типовая для научной статьи):

1. Что сделано (систематизация шести протоколов).
2. Какие метрики введены и с какими порогами.
3. Какая архитектура предложена.
4. Практическая значимость.
5. Дальнейшие шаги.

Заключение не должно содержать новых идей — только обобщение результатов.

7.9 Список источников

16 источников, сгруппированы по типам: научные публикации (1, 2), стандарты (3, 4, 7, 8), вендорские/foundation спецификации (5, 6, 9, 10), вспомогательные ресурсы (11–14), ГОСТ-ы (15, 16). Все приведены к ГОСТ-формату.

8. Глоссарий

Термин	Расшифровка
A2A	Agent-to-Agent — протокол прямой координации автономных агентов (Google, 2025)
CASAO	Collaborative Automated Course of Action Operations — формат плейбуков реагирования
CTI	Cyber Threat Intelligence — разведка киберугроз

Термин	Расшифровка
EDR	Endpoint Detection and Response — система мониторинга на конечных устройствах
FIPA ACL	Стандарт сообщений между агентами (речевые акты), 1990-е
IOC	Indicator of Compromise — индикатор компрометации (IP, домен, хеш)
JSON-RPC 2.0	Протокол вызова процедур поверх JSON
LLM	Large Language Model — большая языковая модель
MCP	Model Context Protocol — стандарт подключения LLM к внешним инструментам (Anthropic, 2024)
MITRE ATT&CK	База тактик и техник атакующих от MITRE Corporation
NDR	Network Detection and Response — обнаружение угроз в сетевом трафике
OASIS	Стандартизационный консорциум (разработчик STIX, TAXII, CACAO, OpenC2)
OCSF	Open Cybersecurity Schema Framework — открытая схема событий безопасности
OpenC2	Open Command and Control — язык команд защиты
SDO / SRO / SCO	STIX Domain / Relationship / Cyber-observable Object
SIEM	Security Information and Event Management — управление событиями безопасности
SOAR	Security Orchestration, Automation and Response — автоматизация реагирования
SOC	Security Operations Center — центр мониторинга и реагирования
SSE	Server-Sent Events — однонаправленный стриминг от сервера к клиенту по HTTP
STIX	Structured Threat Information Expression — формат описания угроз
TAXII	Trusted Automated Exchange of Indicator Information — транспорт STIX по HTTPS
TTP	Tactics, Techniques and Procedures
ЗПК	Задержка распространения контекста
КПК	Коэффициент полноты контекста
КССА	Коэффициент семантической согласованности агентов
Брокер контекста	Центральный архитектурный слой, согласующий форматы и обогащающий контекст между агентами
Плейбук	Описанная последовательность шагов реагирования на инцидент (CACAO-формат)
Confidence Score	Численная оценка уверенности агента в классификации события

9. Вопросы и ответы к защите

9.1 Об актуальности и научной новизне

В: Почему задача актуальна — разве SOAR уже не решает координацию агентов? О: Типовые SOAR оперируют статическими плейбуками, привязанными к классам инцидентов. Они не учитывают LLM-агентов и не имеют формального способа измерить качество обмена контекстом. Если SOAR получает неполное событие, он либо выполнит плейбук на «дырявых» данных, либо отдаст всё человеку — промежуточного формального критерия не существует. Статья этот критерий вводит.

В: В чём конкретно научная новизна? О: В трёх аспектах: (1) единая архитектурная модель, объединяющая четыре уровня обмена, ранее рассматриваемых изолированно; (2) три количественные метрики качества межагентного взаимодействия (КПК, ЗПК, КССА), допускающие

экспериментальную верификацию; (3) пороги, при выполнении которых режим автономного реагирования операционно допустим.

В: Почему именно ваша работа решает эту задачу, а не зарубежные публикации? О: По состоянию на 2025 г. протоколы MCP и A2A появились слишком недавно, чтобы существовали публикации, объединяющие их с CTI-форматами (STIX, OCSF). Работа предлагает синтез на стыке только что устоявшихся стандартов.

9.2 Об архитектуре

В: Брокер контекста — это новое слово или это просто шина данных? О: Это не просто транспорт. Шина данных переносит сообщения «как есть». Брокер контекста добавляет три функции, которых нет у шины: (1) трансляция форматов по явным таблицам соответствия, (2) семантическое обогащение по MITRE ATT&CK, (3) метрические контрольные точки (КПК, ЗРК, КССА). Без этих функций координация LLM-агентов с CTI невозможна.

В: Почему централизованная архитектура брокера — это не «единая точка отказа»? О: Это ограничение признано в разделе 5.3. На уровне предложения это компромисс: распределённый брокер требует консенсуса для согласования онтологии, что в реальном времени сложно. В разделе 5.4 указано направление работ — защита брокера через изолированный аудит и многоуровневую репликацию состояний.

В: Почему именно A2A для уровня оркестрации, а не gRPC или Kafka? О: A2A разработан специально для координации LLM-агентов, предоставляет понятие Agent Card (паспорт возможностей) и Task/Artifact (нативный паттерн «запрос → результат»). gRPC и Kafka — общего назначения, требовали бы построения этих абстракций поверх. На уровне между агентами и оркестратором это излишняя инженерная сложность.

9.3 О метриках

В: Почему именно три метрики, а не одна интегральная? О: Информация, время и семантика — это **независимые** оси качества. Объект может иметь полный набор атрибутов (КПК=1) и быть доставлен мгновенно (ЗРК≈0), но получатель использует другую версию OCSF и не интерпретирует половину полей (КССА<0,5). Свёртка в одну метрику замаскирует тип проблемы — невозможно будет понять, что чинить.

В: Откуда взяты пороговые значения КПК=0,7, ЗРК=500 мс, КССА=0,85? О: Пороги имеют **рабочий характер** — это явно зафиксировано в разделе 3.4. Они выбраны эмпирически: 0,7 — типичная грань между «больше половины полей» и «достаточно для решения»; 500 мс — общепринятая граница SOAR-real-time (см. отраслевые отчёты Gartner и MITRE); 0,85 — типовой порог семантической точности в задачах NLP. Раздел 5.4 указывает на необходимость верификации порогов на реальных данных SOC — это направление дальнейших работ.

В: Можно ли заменить КССА на BLEU/ROUGE из NLP? О: Нет. BLEU/ROUGE измеряют поверхностное сходство строк, а КССА — долю **успешных** интерпретаций сообщений без

запроса уточнения. Это операционная метрика, а не лингвистическая. У КССА простая интерпретация: «доля сообщений, по которым агент не потребовал уточнения», что легко логировать в реальной системе.

9.4 О границах применимости

В: Что если в инциденте нет соответствующей техники в MITRE ATT&CK? О: Это явно зафиксировано как ограничение (раздел 5.3). Для нетиповых атак КССА будет систематически занижен из-за неполноты сопоставления с таксономией, и автономный режим автоматически переключится в полуавтоматический — что корректно с точки зрения безопасности.

В: Что если LLM-агент «выдумает» решение (галлюцинация)? О: Раздел 5.3 указывает на необходимость жёсткой фиксации набора инструментов MCP — агент не сможет выполнить действие, не описанное в его tool-каталоге. Кроме того, плейбук CACAO 2.0 ограничивает пространство допустимых действий заранее одобренными шагами. Галлюцинация в формулировке возможна, но она не приведёт к деструктивному действию.

В: А если атакующий пришлёт специально искажённое, но синтаксически корректное событие? О: Это сценарий состязательного воздействия — отдельная задача, обозначенная в разделе 5.3 и в направлениях дальнейших работ (раздел 5.4). Для защиты предполагается аномальная классификация входящих сообщений по агрегированным признакам.

9.5 О практической применимости

В: Можно ли внедрить ваше решение в существующий SOC, не переписывая всю инфраструктуру? О: Да, и это ключ к практической значимости (см. заключение). Брокер контекста разворачивается параллельно действующей SOAR-инфраструктуре. Существующие плейбуки CACAO 2.0 переиспользуются как базовые исполнительные шаблоны, постепенно мигрируется только логика принятия решений к агентной модели. Технологический риск минимален.

В: Какие требования к производительности к прототипу? О: Раздел 5.4 указывает целевую нагрузку — не менее 10 000 событий в секунду по показателю ЗРК. Это соответствует объёмам типового корпоративного SOC среднего размера.

9.6 Технические вопросы

В: Что произойдёт, если TAXII-сервер с CTI недоступен? О: Enrichment Agent не сможет вернуть STIX-объекты, КПК остаётся на уровне OCSF-нормализации (обычно 0,5–0,7). Брокер видит низкий КПК и передаёт управление аналитику SOC. Это **безопасный отказ** (fail-safe).

В: Почему OpenC2 в архитектуре, если ему уже 6 лет? О: OpenC2 — единственный широко поддерживаемый язык команд защиты, не зависящий от транспорта и вендора. Альтернатив сравнимой зрелости нет. Версия 1.0 (2019) дополняется работающей черновой 2.0 — спецификация развивается.

В: Почему OCSF, а не CIM (Common Information Model) от Splunk? О: OCSF спроектирован как вендор-нейтральный (AWS + Splunk + ещё 200 организаций), передан Linux Foundation в ноябре 2024 г. — это нейтральная площадка. CIM остаётся проприетарной схемой одного вендора.

10. Короткая шпаргалка «что говорить за 3 минуты»

Если на защите попросят рассказать суть за 3 минуты:

- 1. Проблема (30 с).** Современный SOC — это десятки систем разных вендоров. Чтобы они работали как команда автономных агентов, нужны протоколы обмена контекстом. Существует шесть таких протоколов — STIX/TAXII, OCSF, CACAO, OpenC2, MCP, A2A — но ни один не закрывает полный цикл координации.
 - 2. Идея (30 с).** Между агентами нужен промежуточный слой — брокер контекста. Он транслирует форматы, обогащает события по MITRE ATT&CK, маршрутизирует сообщения и ведёт версионированный журнал.
 - 3. Метрики (60 с).** Введены три количественные метрики качества обмена контекстом: КПК (полнота, $\geq 0,7$), ЗПК (задержка, ≤ 500 мс), КССА (семантическая согласованность, $\geq 0,85$). При одновременном выполнении всех порогов агент реагирует автономно, иначе — управление передаётся аналитику SOC.
 - 4. Архитектура (45 с).** Три уровня: автономные агенты (Detection/Enrichment/Response), брокер контекста (4 модуля), оркестратор (использует метрики для принятия решения о режиме реагирования). Взаимодействие — по протоколу A2A через Task/Artifact.
 - 5. Результат и значимость (15 с).** Подход допускает поэтапную интеграцию в существующие SOC параллельно SOAR, переиспользуя плейбуки CACAO 2.0.
-

11. Что читать дальше (если захочется углубиться)

- Спецификации первоисточников: ссылки 3–10 из списка статьи — это основные документы каждого протокола.
 - MITRE ATT&CK Matrix — посмотреть, как устроена база на attack.mitre.org.
 - Книга Котенко И. В. и др. по распределённым системам обнаружения вторжений — теоретическая база мультиагентных защит.
 - Anthropic MCP Server SDK — практический пример MCP-инструмента на Python.
 - Google A2A samples — практические примеры A2A-агентов.
-

Конспект предназначен для самостоятельного освоения материала статьи. Раздел 9 — основа подготовки к защите.